Map security technologies to application requirements



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com





Checking in with Globomantics



Connected Equipment is going global

Last month's logs show injection attempts

Its pipeline signs in with a secret

What do you fix first, and with what?

Start from the requirement, not the product



Absorb a flood: Azure DDoS Protection, network layers 3 and 4

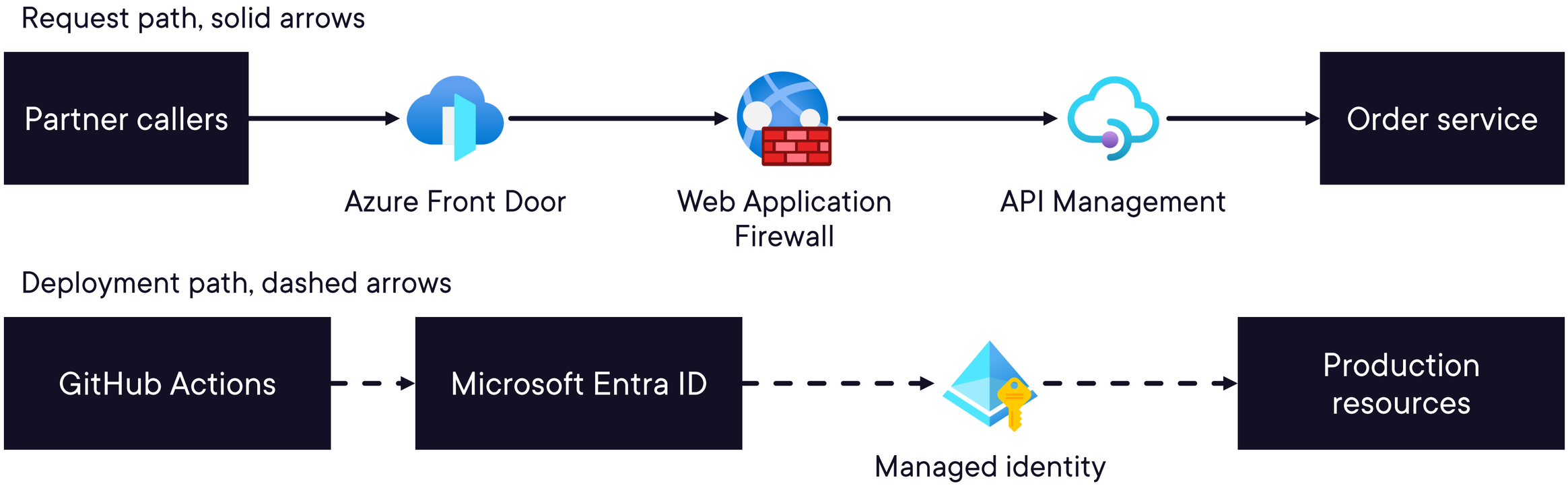


Stop injection: Azure Web Application Firewall, application layer 7



Hide backends: Azure API Management and private endpoints

Follow a request and a deployment



Defender for APIs watches the gateway, and no secret sits on the deployment path

Design workload identities for Azure access

Where the workload runs picks the identity

On Azure: a managed identity

Outside Azure: workload identity federation

Last resort: a service principal with a secret



Standing secret or earned token

Client secret in GitHub	vs.	Federated credential
Reusable by anyone who reads it		Issued per run, short-lived
Valid until someone rotates it		One repo, one environment
Stored where it can leak		Nothing stored to leak

Design API management and security

Know the caller before you trust the call

Subscription key	vs.	Microsoft Entra token
Shared secret, no caller identity		Names the calling application
Good for usage tracking		Carries scopes like Orders.Cancel
Never the only check		Checked on every request

Enforce the API contract in API Management

Requirement	Policy	What it stops
Only valid partner tokens	validate-jwt	Unauthenticated and expired calls
No partner floods the API	rate-limit-by-key	One caller starving the rest
Requests match the contract	validate-content	Malformed or oversized payloads
Responses reveal nothing extra	set-header to remove	Server and framework banners

Place the gateway by who calls it

Internal mode for internal callers

External mode for public partners

Private endpoint for private inbound

Self-hosted gateway near the backend

Watch the gateway with Defender for APIs

Finds unauthenticated and external APIs

Detects OWASP API Top 10 threats at run time

Covers REST APIs in API Management



Design and tune Azure Web Application Firewall

Pick the firewall by where it inspects

Front Door WAF	vs.	Application Gateway WAF v2
Inspects at the global edge		Inspects inside one region
Premium: managed and bot rules		Virtual network integration
Standard runs custom rules only		Per-site and per-URI policies

Sort the bots before they reach the API

Good bots, like search crawlers

Bad bots, like scrapers and scanners

Unknown bots, challenged or logged



Tune it before you enforce it

Start in Detection mode

Build exclusions from the logs

Switch to Prevention mode

Plan every rule set upgrade

Demo: Read the API front door

The edge firewall policy, the gateway policy behind it, and the pipeline's federated credential

Practice question and key points

Theme: Azure Web Application Firewall

Question

Globomantics has an Azure subscription. The Industrial Systems business unit hosts a customer portal on Azure virtual machines. The virtual machines are in a virtual network in a single Azure region.

You need to recommend a solution to protect the portal that meets the following requirements:

- **Block SQL injection attacks against the portal.**
- **Inspect HTTP requests inside the virtual network that hosts the portal.**

Theme: Azure Web Application Firewall

Question

You need to recommend a solution to protect the portal. What should you include in the recommendation?

A. Azure API Management with validate-content policies

B. Azure DDoS Network Protection for the virtual network

C. Azure Application Gateway with Azure Web Application Firewall

D. Azure Front Door Premium with Azure Web Application Firewall

Theme: Azure Web Application Firewall

Answer: C

You need to recommend a solution to protect the portal. What should you include in the recommendation?

A. Azure API Management with validate-content policies

B. Azure DDoS Network Protection for the virtual network

C. Azure Application Gateway with Azure Web Application Firewall

D. Azure Front Door Premium with Azure Web Application Firewall

Checking out with Globomantics



Map each requirement to its layer

Replace stored secrets with federation

Enforce the contract in the gateway

Tune the edge firewall, then enforce